

Week 6 – Security Assessment & Penetration Testing Report

Objective

The objective of Week 6 was to perform practical security testing using industry-standard tools, identify vulnerabilities, document test results, and propose appropriate security improvements following best practices. The activities included web application scanning, container security analysis, and manual penetration testing techniques.

Tools Used

- **Nikto** – Web server vulnerability scanner
 - **OWASP ZAP** – Automated web application security scanner
 - **Burp Suite Community Edition** – Manual web application testing
 - **Docker** – Containerization platform
 - **Trivy** – Container image vulnerability scanner
 - **Kali Linux** – Security testing environment
-

Task 1: Web Application Security Scanning

1.1 Nikto Web Server Scan

Target:

Intentionally vulnerable test web application (vulnweb)

Actions Performed:

- Executed Nikto scan against the target web server
- Generated and saved the Nikto vulnerability report
- Collected screenshots showing scan execution and results

Findings:

- Server information disclosure (web server and PHP version exposed)
- Missing security-related HTTP headers
- Potentially insecure server configuration
- Use of outdated server-side components

Security Improvements (Recommended):

- Disable server version disclosure (ServerTokens, X-Powered-By)

- Update web server and PHP to supported versions
 - Add essential HTTP security headers:
 - Content-Security-Policy
 - X-Frame-Options
 - X-Content-Type-Options
 - Restrict unused HTTP methods
 - Apply secure server hardening guidelines
-

1.2 OWASP ZAP Automated Scan

Actions Performed:

- Conducted an automated active scan using OWASP ZAP
- Generated and reviewed the HTML scan report
- Captured multiple screenshots of scan progress and results

Findings:

- Missing or weak security headers
- Potential input reflection vulnerabilities
- Lack of proper browser-side protection mechanisms

Security Improvements (Recommended):

- Implement Content Security Policy (CSP)
 - Enable clickjacking protection using X-Frame-Options
 - Enforce secure cookie attributes (HttpOnly, Secure)
 - Validate and sanitize all user inputs server-side
 - Deploy Web Application Firewall (WAF) rules for common attack patterns
-

Task 2: Container Security & Best Practices

2.1 Docker Image Vulnerability Scanning

Actions Performed:

- Verified Docker installation
- Installed and executed Trivy for container image scanning

- Scanned container images for known vulnerabilities
- Captured vulnerability scan results and screenshots

Findings:

- Presence of High and Medium severity vulnerabilities
- Outdated OS packages inside container images
- Security risks due to large base images

Security Improvements (Recommended):

- Use minimal base images (e.g., Alpine Linux)
 - Regularly scan container images before deployment
 - Apply OS and package updates frequently
 - Use multi-stage Docker builds
 - Avoid running containers as root
 - Enforce container runtime security policies
-

Task 3: Manual Penetration Testing (Burp Suite)

3.1 Passive Scanning & Traffic Analysis

Actions Performed:

- Configured Burp Suite scope
- Generated controlled traffic using Burp's built-in browser
- Observed passive scan findings
- Captured screenshots of passive scan results

3.2 Manual Input Testing

Actions Performed:

- Sent HTTP requests to Burp Repeater
- Tested input reflection behavior
- Conducted baseline and XSS reflection tests
- Verified reflected input in HTML context

Findings:

- Reflected user input detected

- Potential risk of Cross-Site Scripting (XSS)
- Lack of output encoding controls

Security Improvements (Recommended):

- Implement strict input validation (allowlists)
 - Encode all user input before rendering in HTML
 - Apply output encoding libraries
 - Deploy Content Security Policy (CSP)
 - Use modern frameworks with built-in XSS protection
 - Apply WAF filtering for malicious payloads
-

Summary of Vulnerabilities & Remediation

Tool	Vulnerability Identified	Recommended Security Improvement
Nikto	Server information leakage	Disable version disclosure
Nikto	Missing headers	Add HTTP security headers
ZAP	Weak security configuration	Implement CSP & XFO
Trivy	Vulnerable container images	Use minimal images & updates
Burp Suite	Reflected input (XSS risk)	Encode output & sanitize input

Conclusion

In Week 6, multiple security assessment tools were successfully used to identify vulnerabilities across web applications and containerized environments. The results demonstrate the importance of layered security controls, regular vulnerability scanning, secure configuration, and adherence to best practices. While no direct remediation was applied to the test environment, detailed security improvement recommendations were documented to reflect real-world production security practices.

Evidence Collected

- Nikto scan screenshots and report
- OWASP ZAP scan screenshots and HTML report
- Trivy container scan screenshots

- Burp Suite passive and manual testing screenshots

All evidence has been organized and saved according to the internship documentation structure.

Note on Deployment:

The application tested during this assessment is an intentionally vulnerable demonstration platform used exclusively for security testing and learning purposes. As the application is not owned or maintained by the tester, direct remediation and redeployment were not feasible.

However, all identified vulnerabilities were analyzed, and detailed security improvement recommendations were documented following industry best practices. These recommendations represent the applied security improvements that would be implemented in a real production environment.